

Cybersecurity

Intrusion Detection, Snort, and Network Security Monitoring

Lesson 12.2



Learning Objectives

By the end of today's lesson, you will be able to:

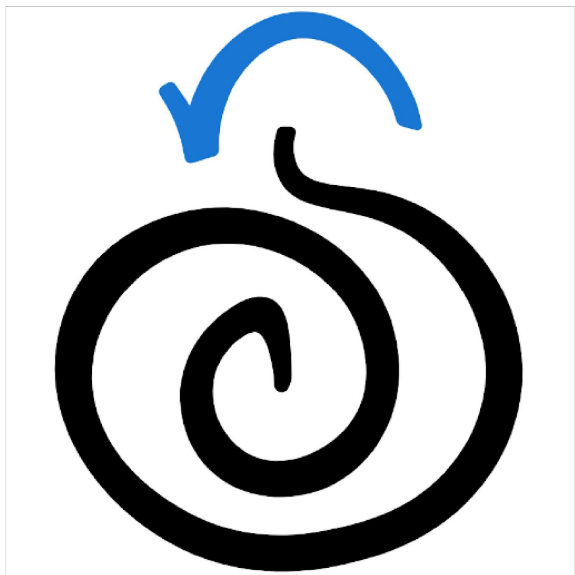
- 1 Interpret and define Snort rules and alerts.
- 2 Explain how intrusion detection systems work and how they differ from firewalls.
- 3 Use Security Onion and its suite of network security monitoring tools to trace the path of network attacks.
- 4 Collect and analyze indicators of attack (IOA) and indicators of compromise (IOC) using NSM tools.
- 5 Apply knowledge of NSM, Snort rules, and Security Onion to establish situational awareness within a network.



Welcome



Security Onion Setup



Before we get started, we will need to log in to Azure and launch an instance of Security Onion.

Then we will generate alert data that we'll use later in the lesson. Specifically, a Security Onion VM will spin up and loaded PCAPs will be replayed.



Let's Recap



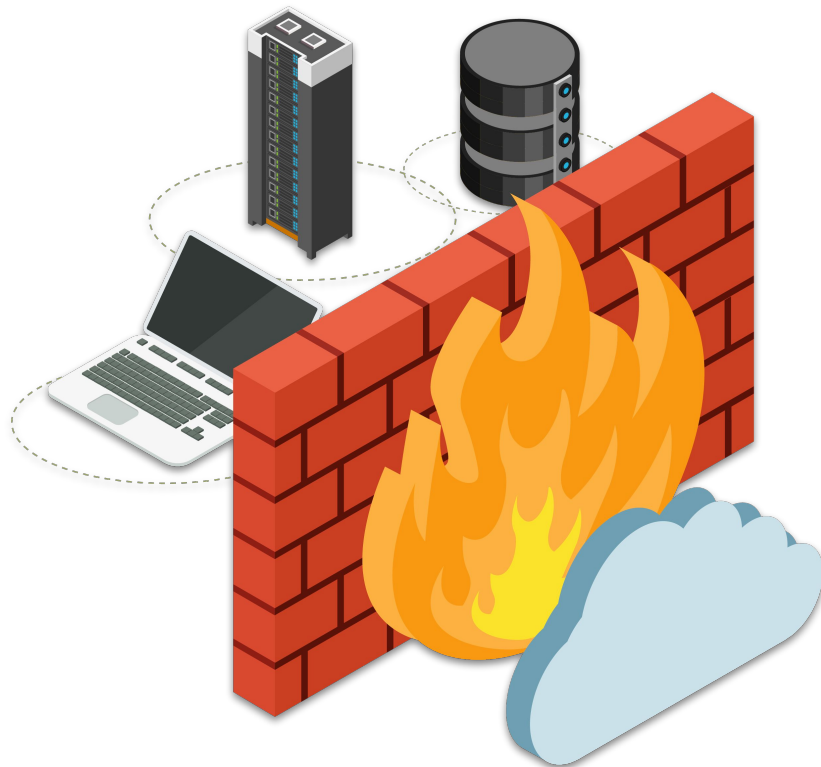
Recap

Network security

Firewalls play a critical role in establishing a perimeter defense.

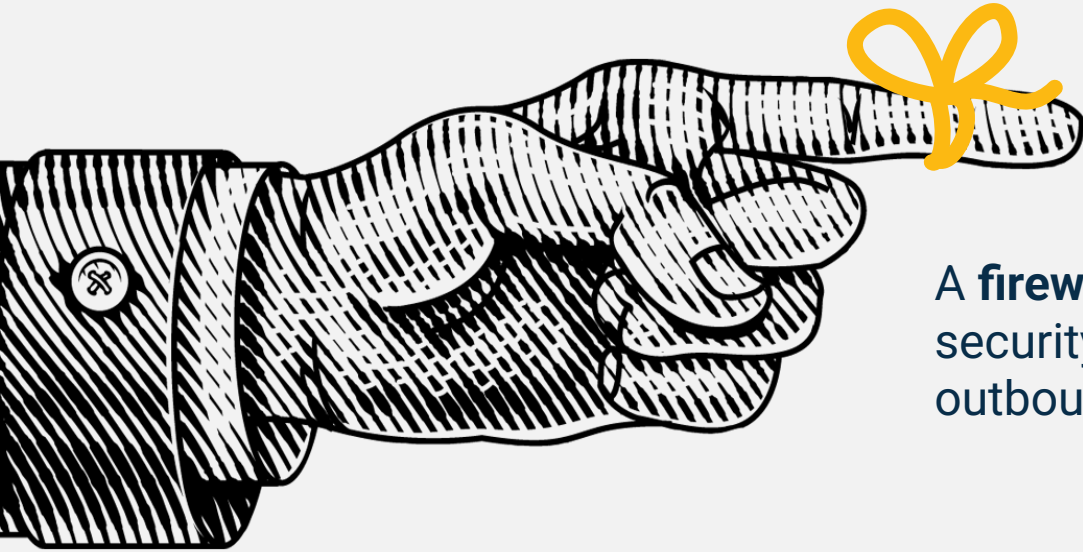
Firewalls do have their limitations. Advanced hackers can easily fool them through packet manipulation.

It's crucial to have a strong defense to help protect sensitive data.



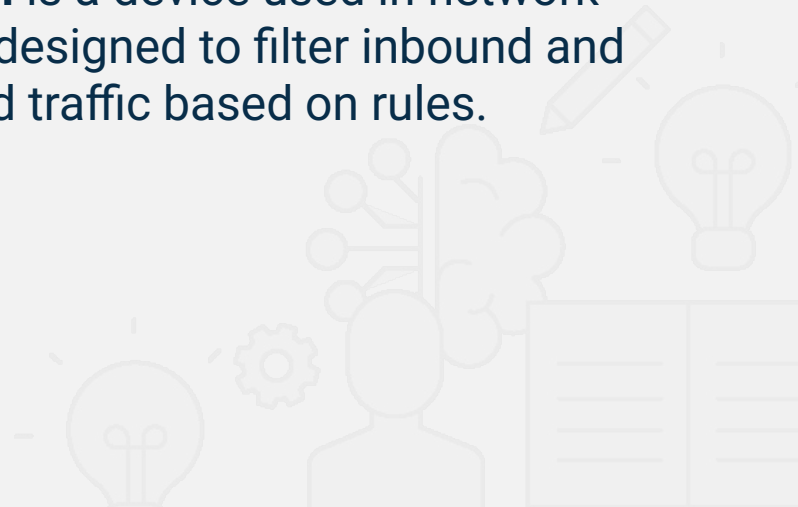


Intrusion Detection Systems (IDSs) and Snort



Remember

A **firewall** is a device used in network security designed to filter inbound and outbound traffic based on rules.



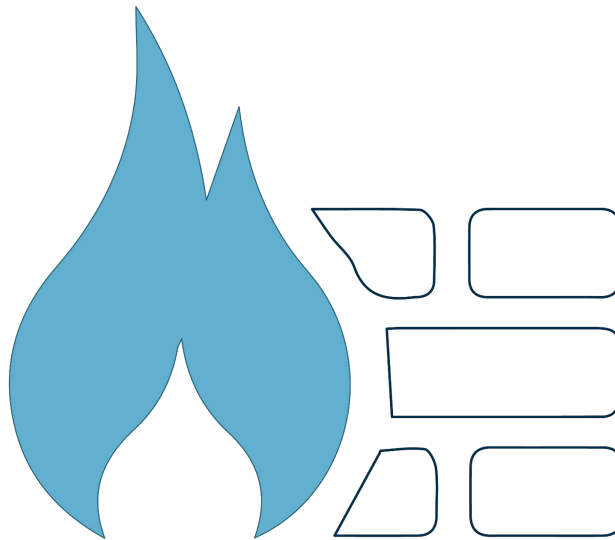


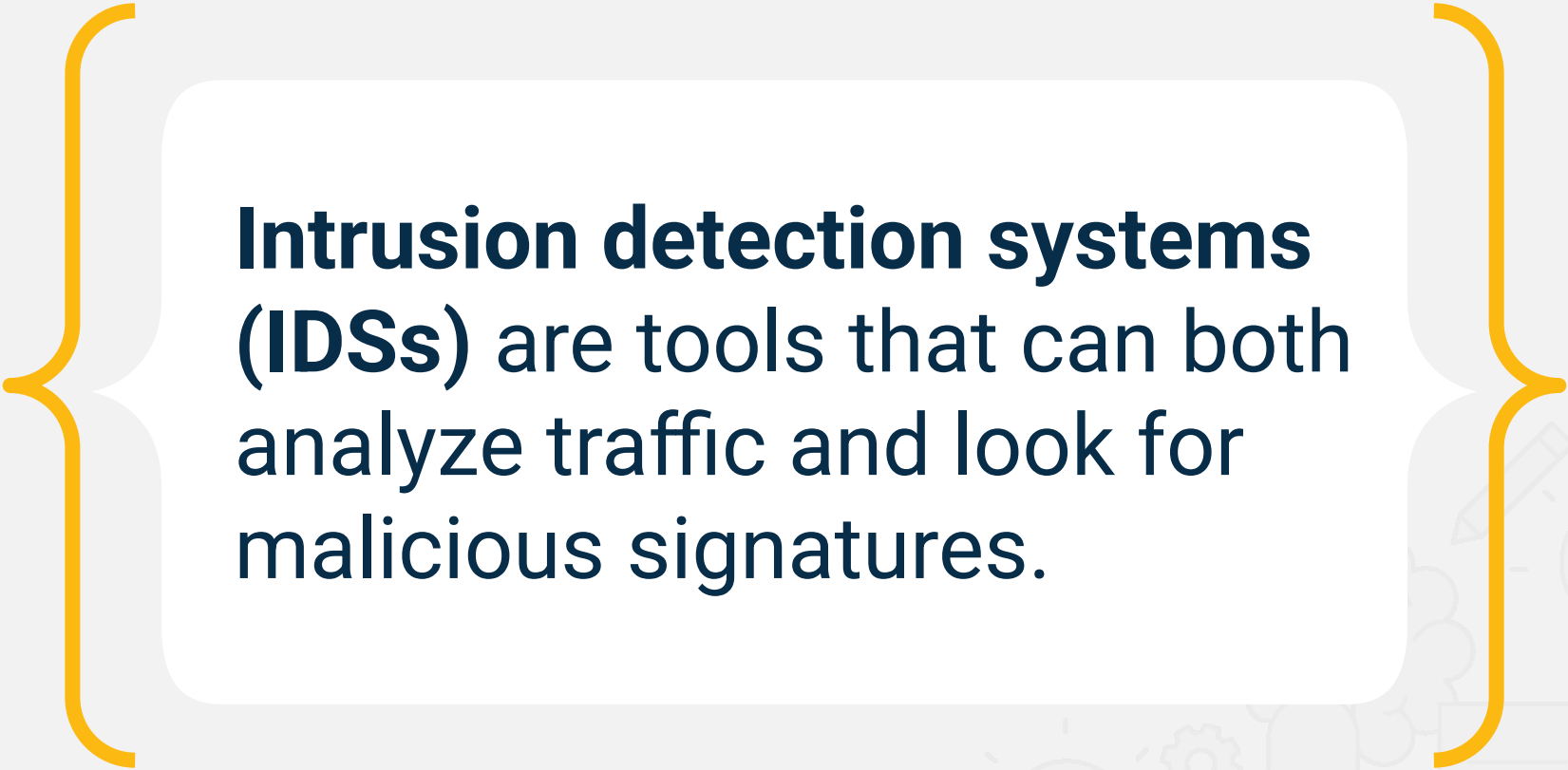
Firewalls Vs. IDSs

Firewalls make decisions to either allow or block traffic based on:

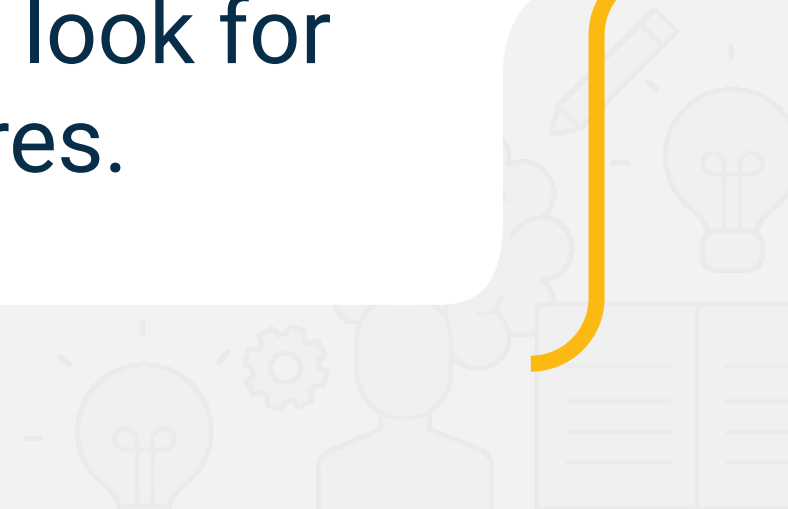
- Source and destination IP address
- Source and destination Port Number
- Protocol type

Firewalls can be fooled through packet manipulation by clever hackers.





Intrusion detection systems (IDSs) are tools that can both analyze traffic and look for malicious signatures.



IDS

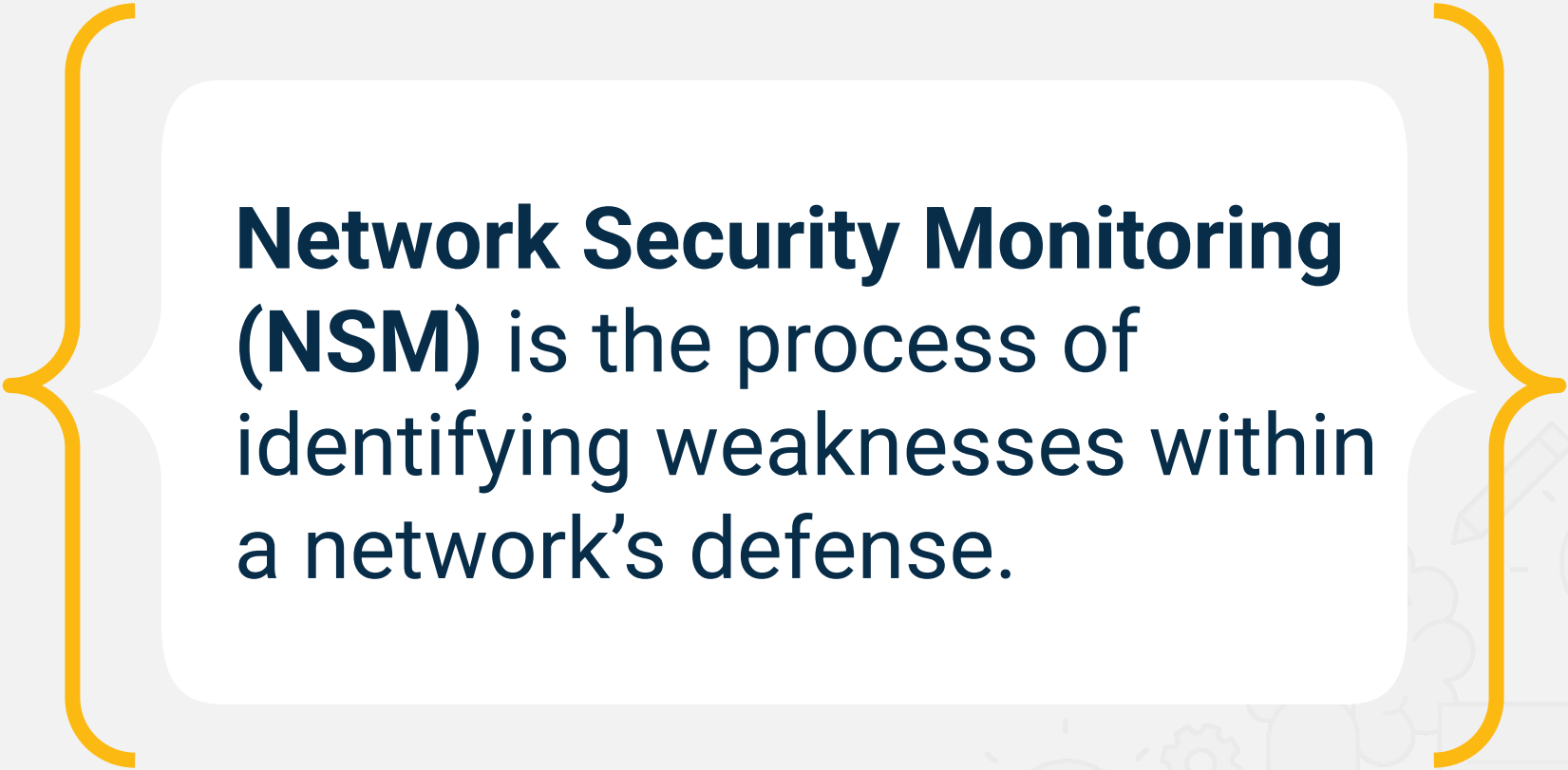
Intrusion detection system



An IDS is like a firewall in that it also:

- Reads the data in the packets
- Performs inspections
- Issues alerts or alarms
- Blocks malicious traffic

There are many IDSs, but today's lesson will be focusing on **Snort**.



Network Security Monitoring (NSM) is the process of identifying weaknesses within a network's defense.

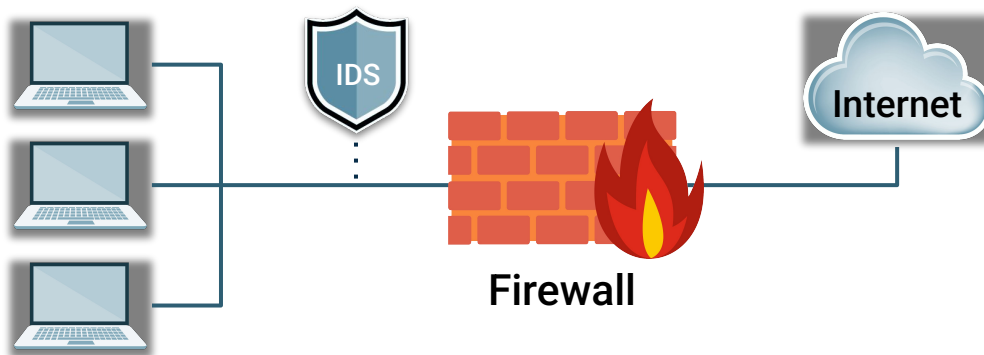




Intrusion Detection Systems

An IDS detects and alerts of an attack.

- 1 An IDS is passive.
- 2 It does not respond to attacks, it only logs and documents information for future analysis.
- 3 It helps organizations establish situational awareness of attackers and harden defenses.



IDS Types

There are two types of IDSs:

01

Signature-based IDS

Compares patterns of traffic to predefined signatures.

- Good for identifying well-known attacks
- Can be updated as new attack signatures are released
- Vulnerable to attacks through packet manipulation
- Unable to detect zero-day attacks

02

Anomaly-based IDS

Compares patterns of traffic against a well-known baseline.

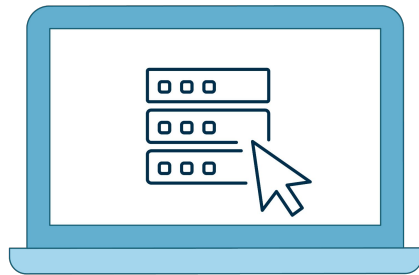
- Good for detecting suspicious traffic that deviates from well-known baselines
- Excellent at detecting when attackers probe and sweep a network
- Prone to false alerts
- Assumes network behavior does not deviate from well-known baselines

IDSs Have Two Basic Architectures



Network IDS (NIDS)

Filters an entire subnet
on a network

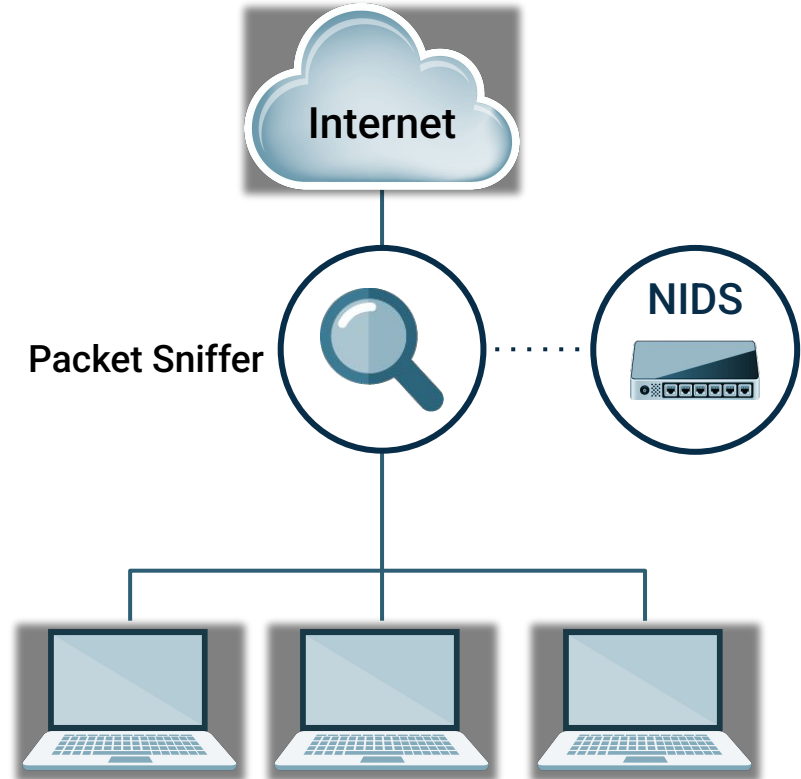


Host-Based IDS (HIDS)

Runs locally on a host-based
system, or user's workstation
or server

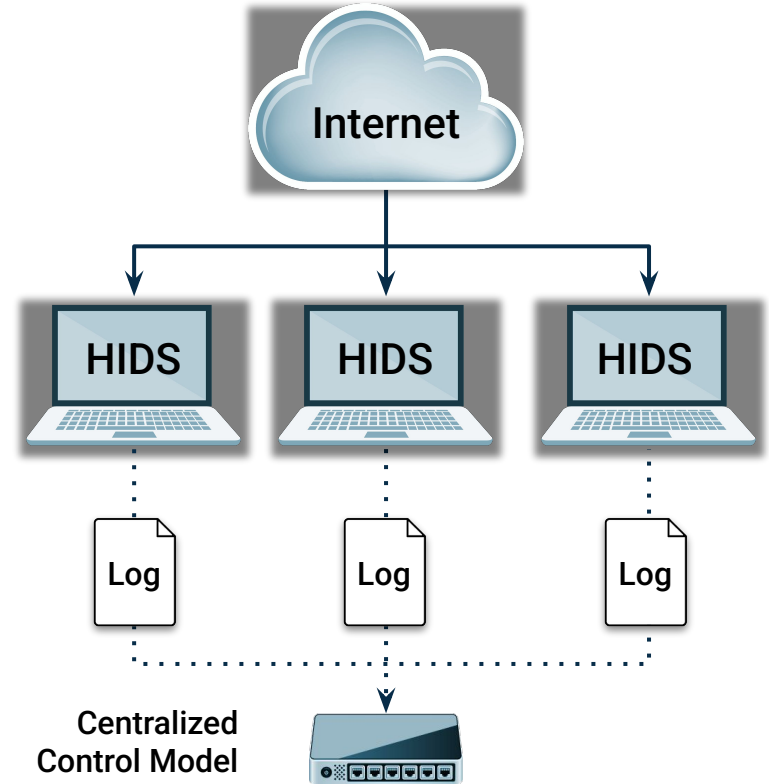
Network IDS (NIDS)

- Matches all traffic to a known library of attack signatures
- Passively examines network traffic at points that it's deployed
- Relatively easy to deploy and difficult to detect by attackers



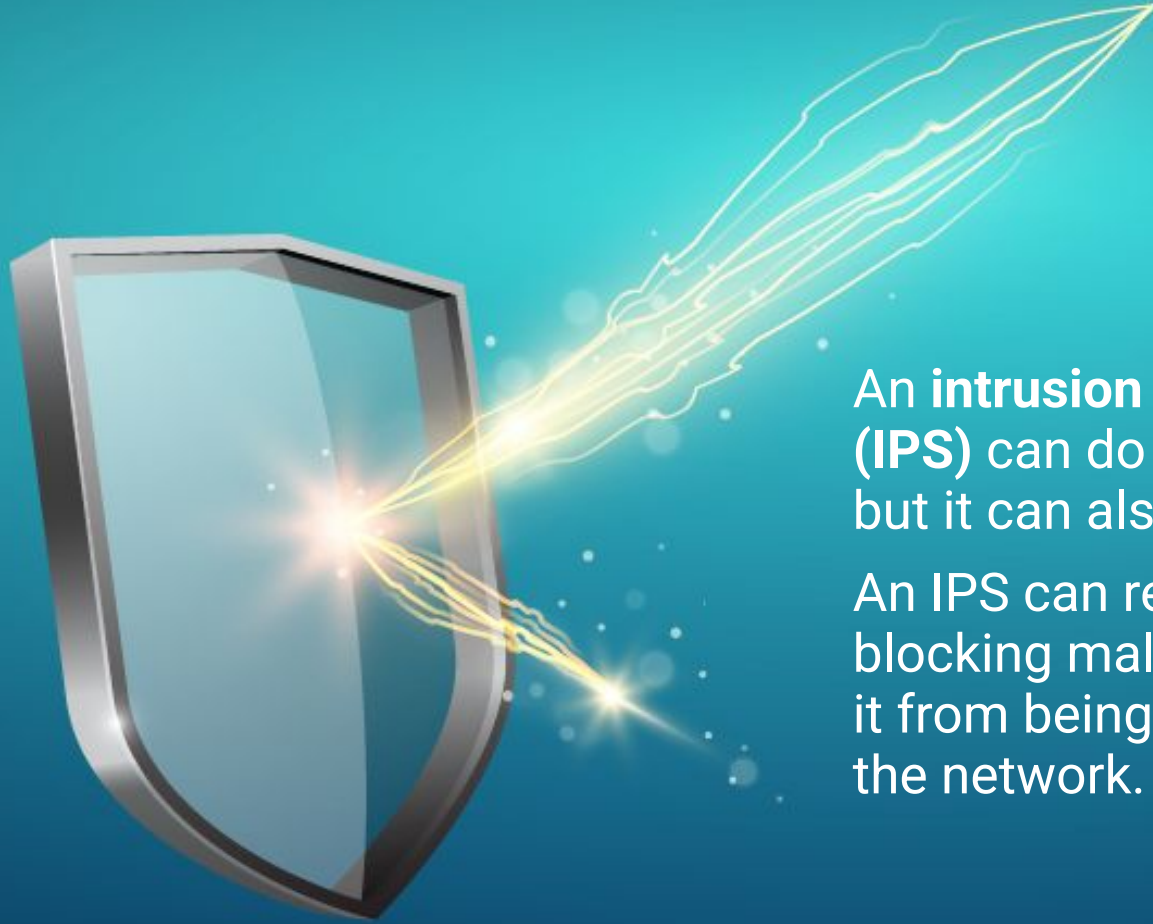
Host-Based IDS (HIDS)

- Acts as a second line of defense against malicious traffic that successfully gets past a NIDS
- Examines entire file systems on a host, compares them to previous snapshots or baselines, and generates an alert if there are significant differences between the two





Intrusion Prevention System (IPS)



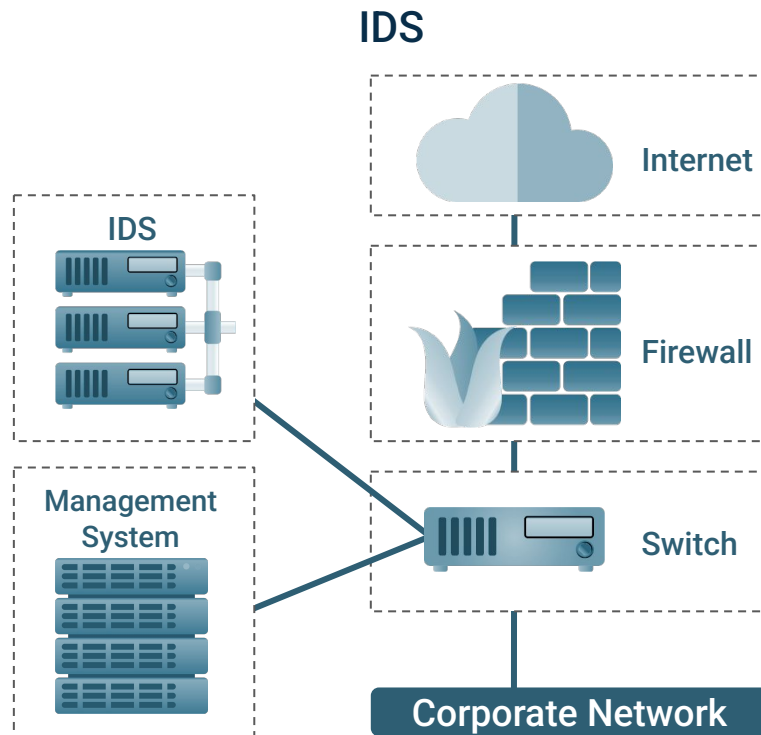
An **intrusion prevention system (IPS)** can do everything an IDS can, but it can also respond to attacks.

An IPS can react to packets by blocking malicious traffic, preventing it from being delivered to a host on the network.

IDS Vs. IPS

An IDS connects via a network TAP or mirrored SPAN port.

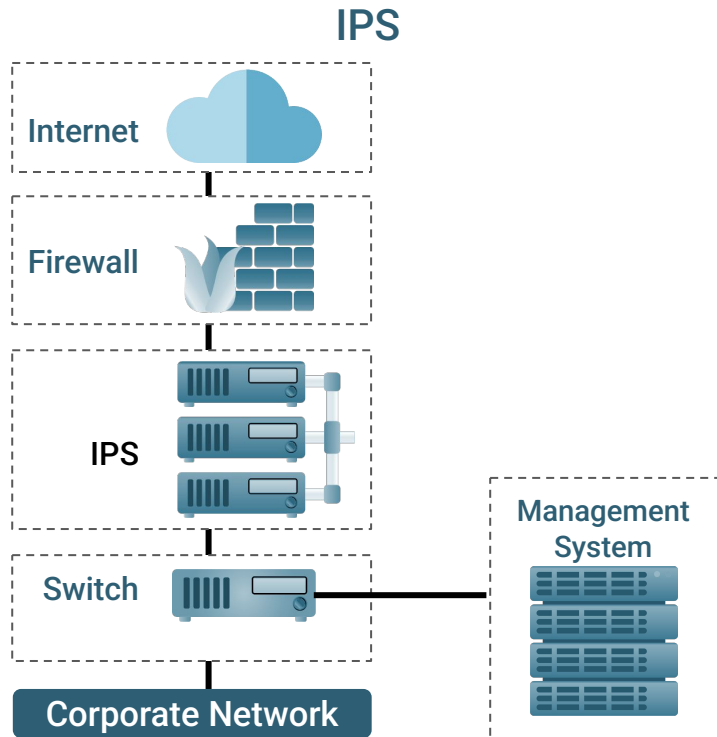
- **Network TAP** is a hardware device that provides access to a network. Network TAPs transit both inbound and outbound data streams on separate channels at the same time so all data will arrive at the monitoring device in real time.
- **SPAN** sends a mirror image of all network data to another physical port where the packets can be captured and analyzed.
- An **IDS** requires an administrator to react to an alert by examining what was flagged.



IDS Vs. IPS

An IPS connects **inline** with the flow of data, typically between the firewall and network switch.

- An IPS requires more robust hardware due to the amount of traffic.
- It will automatically take action by blocking and logging a threat, so it doesn't require administrative intervention.



IDS

Alerts are generated when a rule detects a malicious signature or traffic.



An alert message that's created and sent goes to the analyst's console as an **IOA**.

There are **two** primary types of indicators: **IOA** and **IOC**.

IDS Alerts

Indicators can be either:

Indicator of attack

IOAs indicate attacks happening in real time.

- Proactive approach to intrusion attempts
- Indicate that an attack is in progress, but a full breach has not been determined
- Focus on revealing the intent and end goal of an attacker, regardless of the exploit or malware used

Indicator of compromise

IOCs indicate previous malicious activity.

- Indicate that an attack has occurred, resulting in a breach
- Used to establish an adversary's techniques, tactics, and procedures (TTPs)
- Expose all vulnerabilities used in an attack, giving network defenders the opportunity to revamp their defense as part of their mitigation strategy



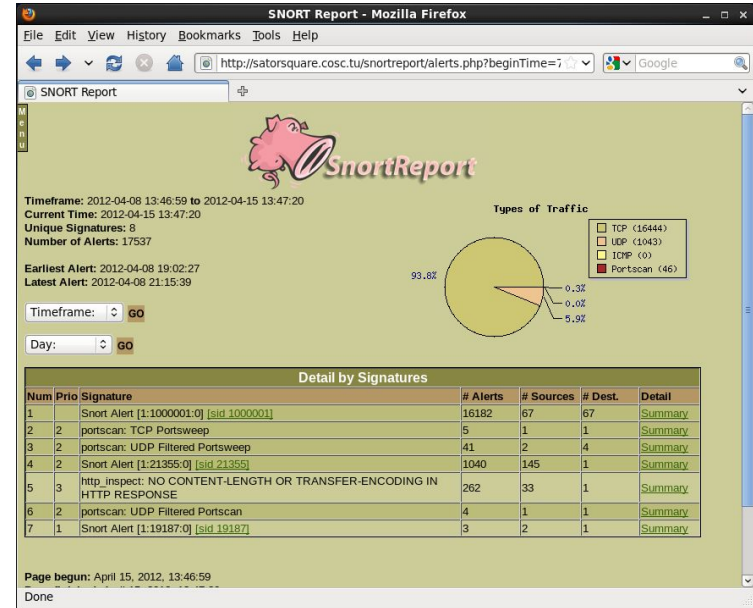
Snort is one of the world's most popular open-source network IDSs/IPSs.

Snort

Snort can perform real-time traffic analysis and log packets on a network.

It adds additional layers of defense that can be applied at various layers of the defense-in-depth model, including:

- Perimeter IDS and IPS architecture
- Network IDS and IPS architecture
- Host IDS and IPS architecture



Snort

Snort can operate in three different modes:

Sniffer

Reads network packets and displays them on screen



Packet Logger

Performs packet captures by logging all traffic to disk



NIDS

Monitors network traffic, analyzes it, and performs specific actions based on administratively defined rules



Snort Rules

Snort uses rules to detect and prevent intrusions. It operates by:

01

Reading a configuration file

02

Loading the rules and plugins

03

Capturing packets and monitoring traffic for patterns specified in the loaded rules

04

generating an alert when traffic matches a rule pattern or else logging the matching packet for later inspection

Snort Rules

Rules direct Snort to monitor for:

OSI Layer

- Watch for IP and TCP data

Source and Destination Address

- Traffic flow

Byte Sequences

- Patterns in packets



Snort Rules

This rule logs the message “**IP Packet Detected**” when it detects an IP packet.

```
alert ip any any -> any any {msg: "IP Packet Detected";}
```

Snort Rules

Rule Header

alert
Action Snort
will take when
triggered

any
Applies to
packets coming
from any source
IP address

10.199.12.8
The destination
IP address

alert tcp any any -> 10.199.12.8 21

tcp
Applies rule
to all TCP
packets

any
Applies the
rule to packets
from any port

21
Applies the rule
to traffic to
destination port 21

Rule Option

{msg: "TCP Packet Detected";}

{msg: "TCP Packet Detected";}
The message printed with the alert



Activity

Intrusion detection systems and Snort

In this activity, you will play the role of an SOC analyst for the California Department of Motor Vehicles (DMV).

- Your CISO has advised you to implement new security controls as an added layer of protection for the driving records of all state citizens.
- In this activity, you will strengthen your knowledge of the concepts related to IDSs and Snort.

Suggested Time
15 minutes



Time's Up!
Let's review



Questions?





NSM and Security Onion



Network Security Monitoring

NSMs can provide situational awareness for an entire network.



We will review Security Onion, which uses **Suricata** as its event-driven mechanism.

Suricata provides Security Onion with alerts based upon configured rules similar to **Snort** rules.

Suricata provides features such as:

- TLS certificates
- HTTP requests
- DNS transactions

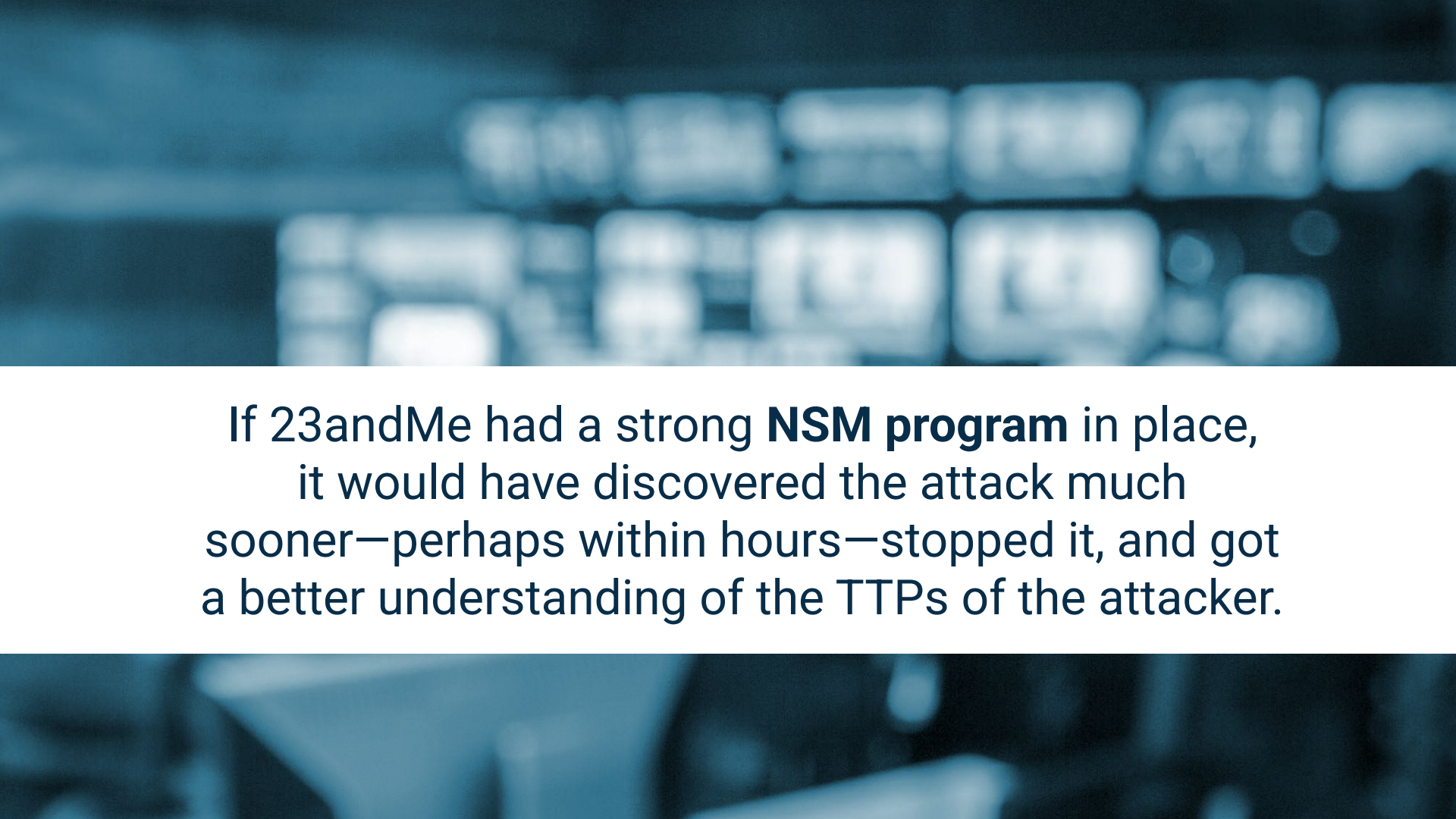
NSM Case Study

On October 2023, a group of attackers released confidential information from 23andMe, a company that offers DNA testing. The exposed information contained personally identifiable information (PII) for many of its users, including usernames, full names, home addresses, social security numbers, and genealogical information.

Assailants had lurked on 23andMe's network for about two months.

- The compromise was achieved using a technique known as “**credential stuffing**.”
- PII of many of its users was exposed.
- 23andMe suffered enormous damage to its reputation.



The background of the slide is a blurred image of a computer workstation. It shows several monitors displaying various data and a keyboard in the foreground. The overall color scheme is a cool blue, giving it a technological and professional appearance.

If 23andMe had a strong **NSM program** in place, it would have discovered the attack much sooner—perhaps within hours—stopped it, and got a better understanding of the TTPs of the attacker.



NSM is most useful
when the **frontend**
layers of defense
are compromised.

NSM

Work to slow or eliminate threat-based attacks



NSMs are:

- Threat-Centric
 - Primary focus is adversary
- Focused on Visibility of Attack
 - Not the response to the attack
- Reveal Statistical Data
 - Specific **IOAs** and **IOCs** from attacks

NSM Strengths

NSM allows organizations to:



Track adversaries through a network and determine their intent



Acquire intelligence and situational awareness



Be proactive by identifying vulnerabilities



Be reactive through incident response and network forensics



Provide insights related to advanced persistent threats (APTs)



Uncover and track malware

NSM Weaknesses

NSM capabilities are extremely limited in the following situations:



Encrypted traffic and VPNs



Underpowered hardware



Mobile communication platforms



Legal and privacy issues



Limited access to network taps



NSM Stages and Processes

NSM operates in two stages, each involving two processes:

01

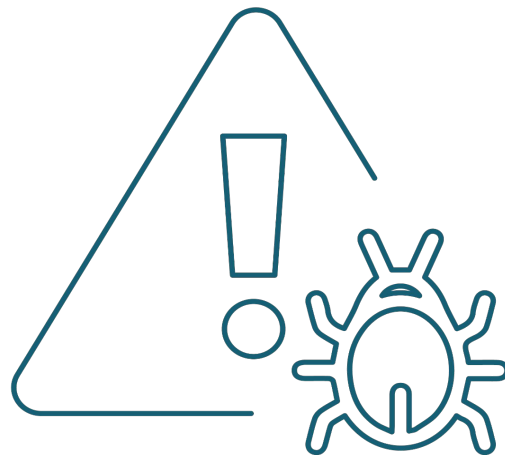
Detection

An alert is generated in the Security Onion analyst console.

02

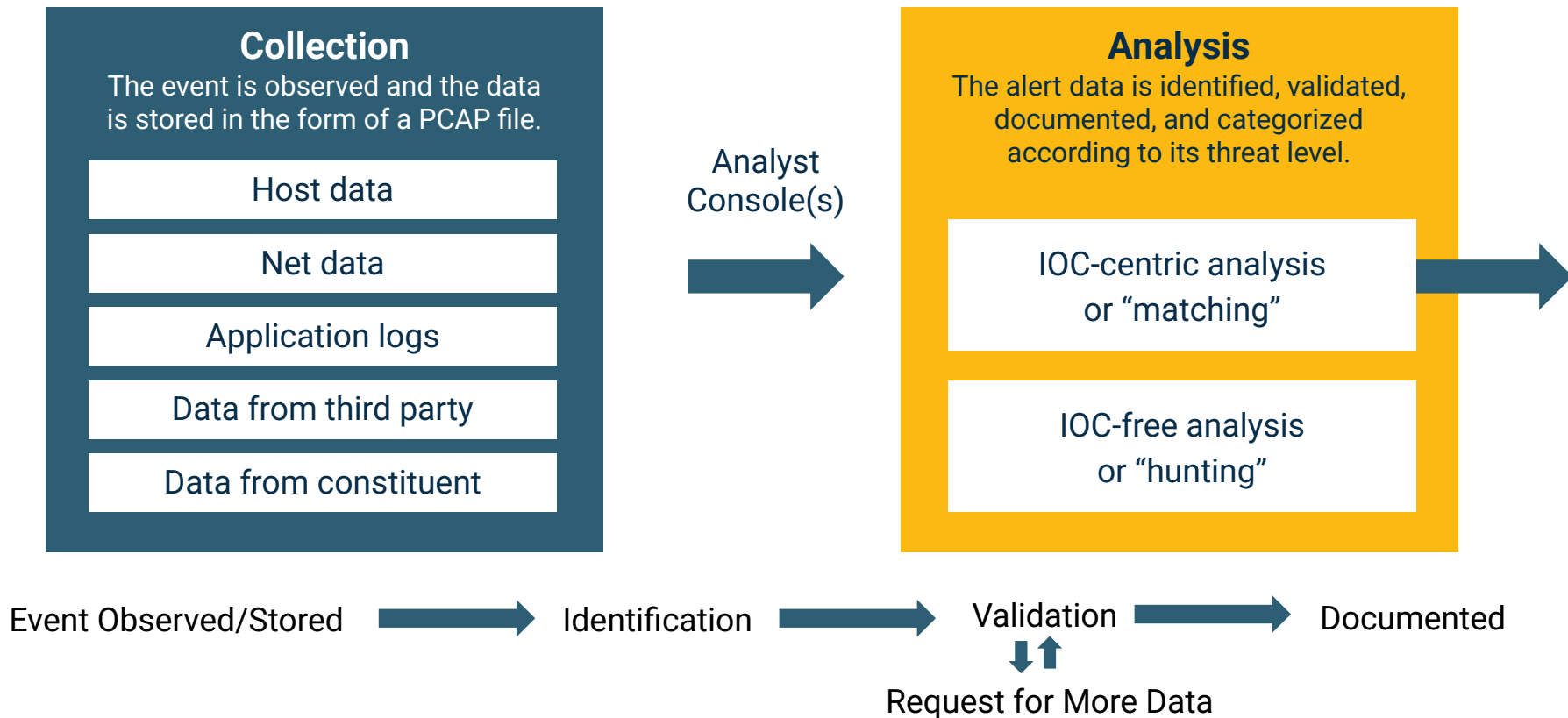
Response

A security team responds to a security incident.



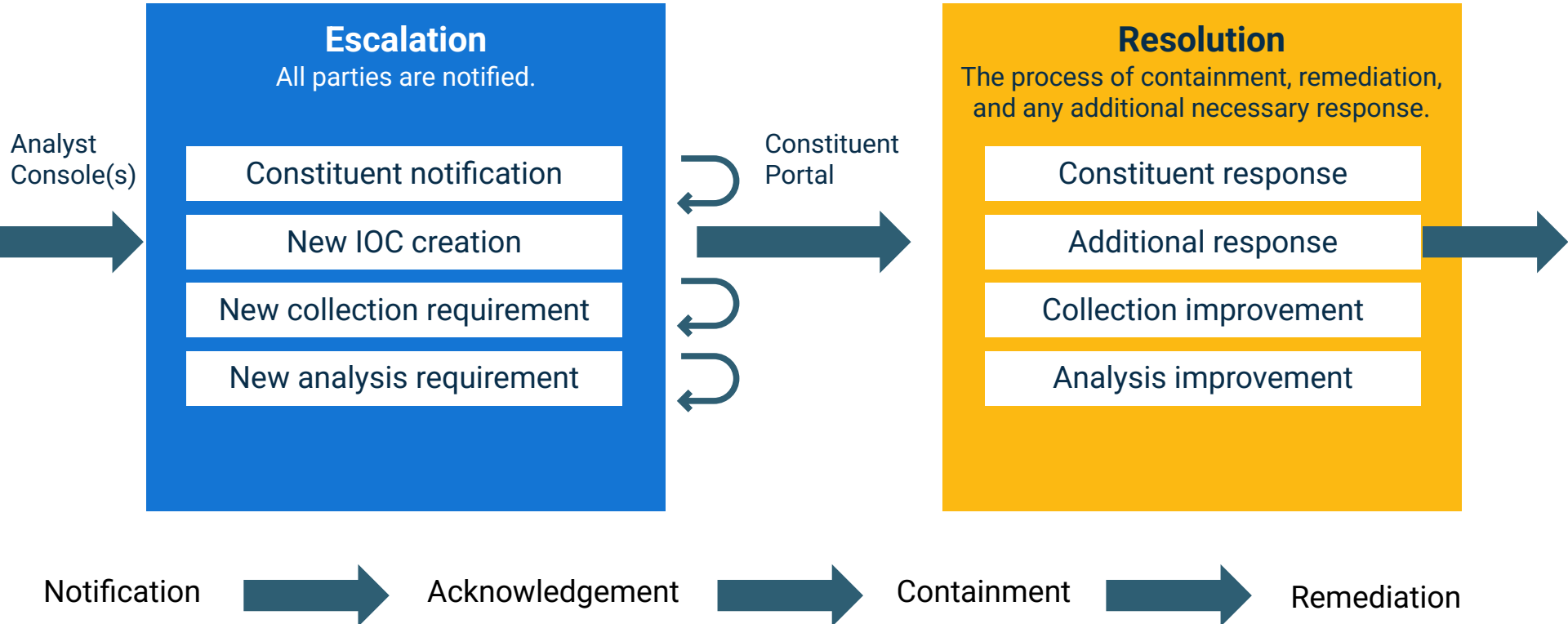
NSM Stages and Processes

Detection: An alert is generated in the Security Onion analyst console.



NSM Stages and Processes

Response: Security team responds to a security incident with two processes:

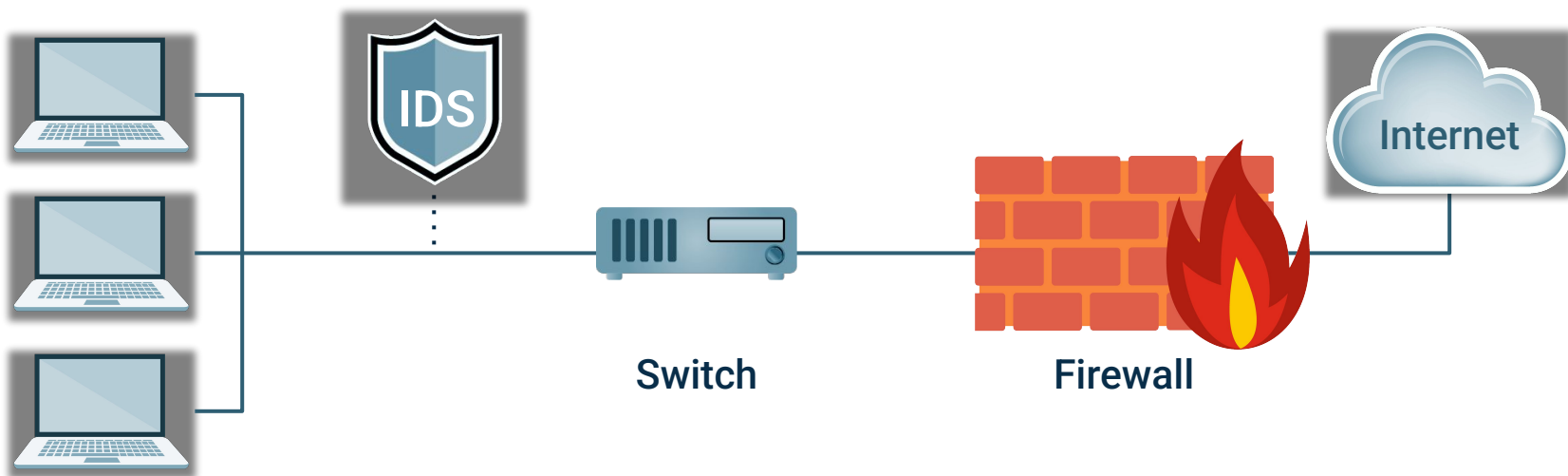




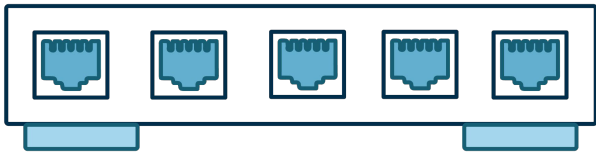
IDSs

IDSs are generally placed at strategic points where traffic is most vulnerable.

These devices are typically placed next to a router or switch that filters traffic.

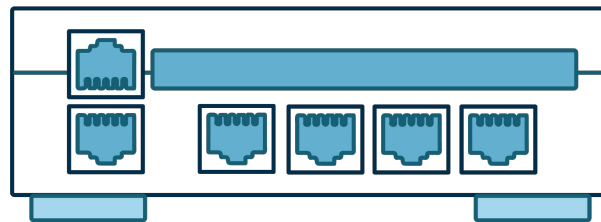


NSM Sensor Connectivity



SPAN or Mirrored Port

Function of an enterprise-level switch that allows you to **mirror one or more physical switch ports** to another port.



Network TAP

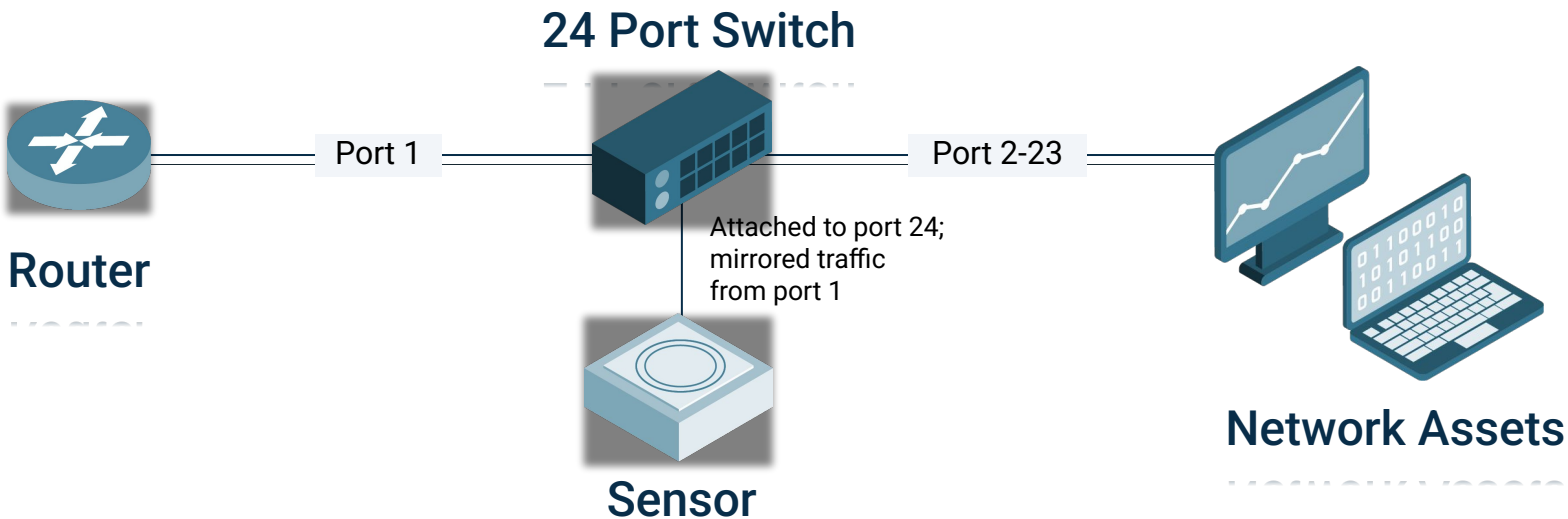
The most common type is an aggregated TAP in which a cable connects the TAP monitor port with the NIC on the sensor. This specific placement allows **traffic to be monitored between the router and switch.**



NSM Sensor Connectivity

SPAN or mirrored port

With a SPAN port, the IDS can perform packet captures on all inbound and outbound traffic in a network.

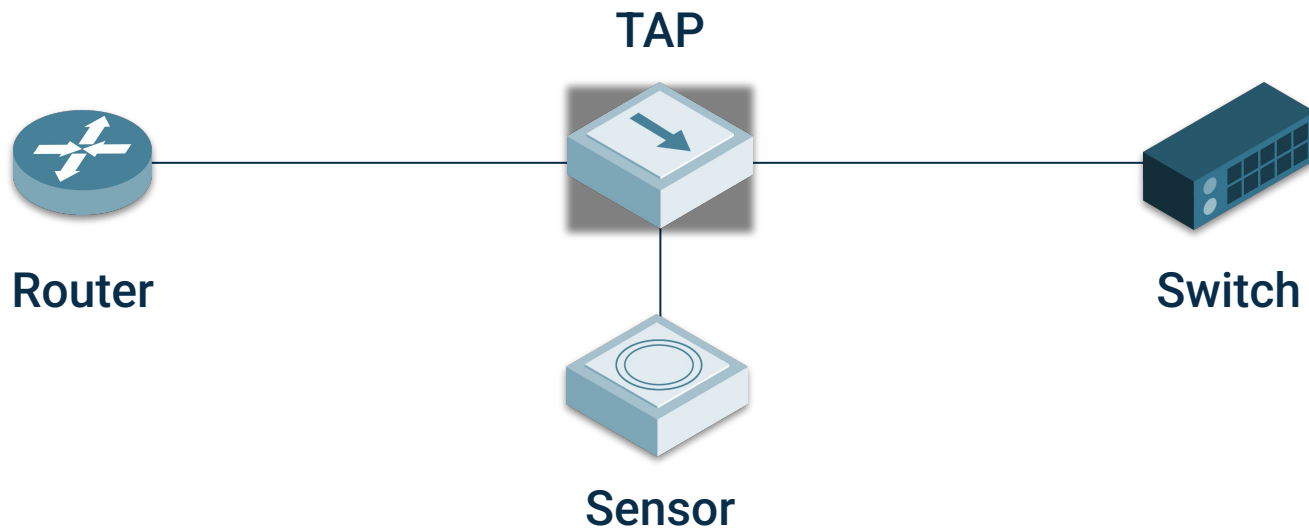




NSM Sensor Connectivity

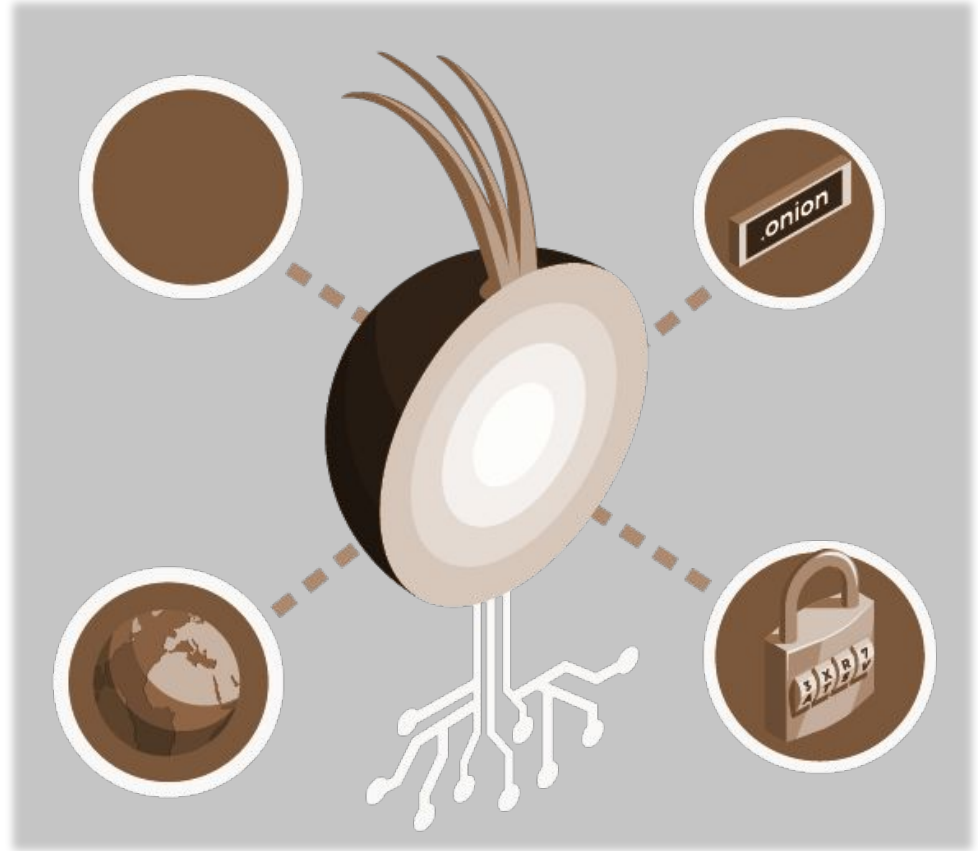
Network TAP

TAPs allow us to access our network and send that data in real time to our monitoring systems.



Security Onion is an NSM platform that provides context, intelligence, and situational awareness of a network.

Security Onion 2.4 is based upon Oracle Linux 9.

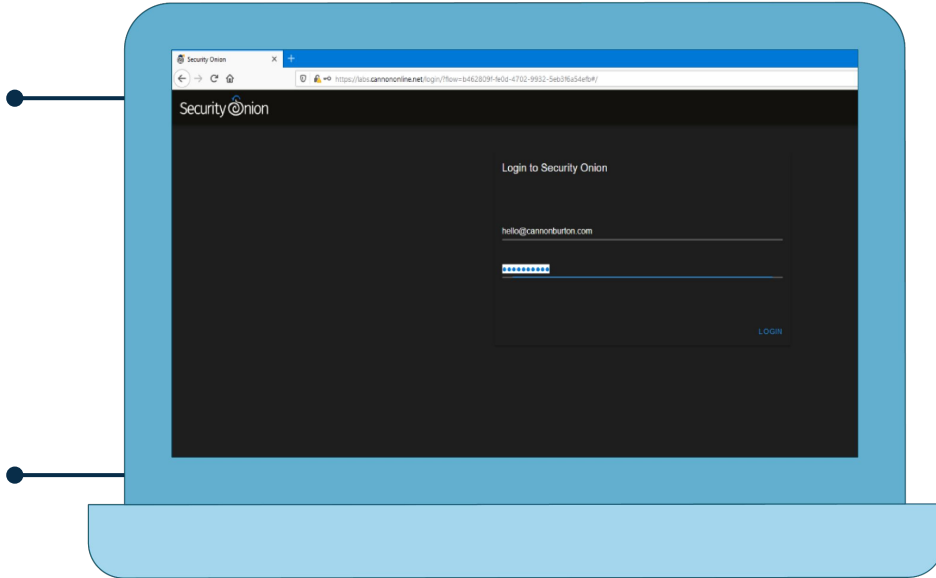


Security Onion

There are two ways to work with Security Onion:

Shell Interface

Web Browser





Security Onion contains a variety of **NSM tools** used to monitor and protect networks from attacks.



Security Onion

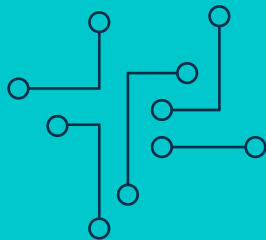
NSM tools



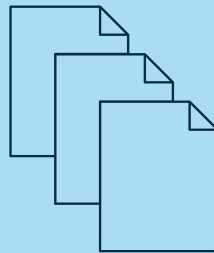
Alerts



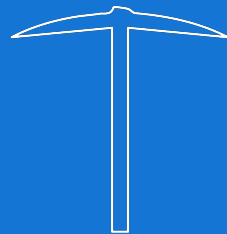
Hunt



PCAP



Cases



NetworkMiner

Security Onion Alerts

Security Onion Alerts has six key functions that help with analysis:

01

Performs simple aggregation of alert data records

02

Makes available certain types of metadata

03

Allows queries and review of alert data

04

Allows queries and review of session data

05

Allows easy transitions between alert or session data and full content data

06

Counts and classifies events, enabling escalation and other incident response decisions

Security Onion Interface

Security Onion has four main sections:

1. Alert Count

Displays a total for the number of events of a specific type

2. Rule Name

The Suricata rule that generated the alert, obtained from the IDS engine

3. Event Module

The module that detected the event (Suricata)

4. Event Severity

Provides a rating for how severe an event should be considered

Security Onion Alert Panel

The screenshot displays the Security Onion Alerts interface. At the top, the 'Alerts' section is visible with an 'Options' dropdown. A search bar is set to 'Group By Name, Module'. The time range is 'Last 24 hours'. A 'Total Found: 163' indicator is present. Below the search bar, there are controls for 'Fetch Limit' (set to 500) and 'Filter Results'. The main table lists alerts with columns for 'Count', 'rule.name', 'event.module', and 'event.severity_label'. Red arrows and boxes highlight specific data points in the first row of the table.

1. Count

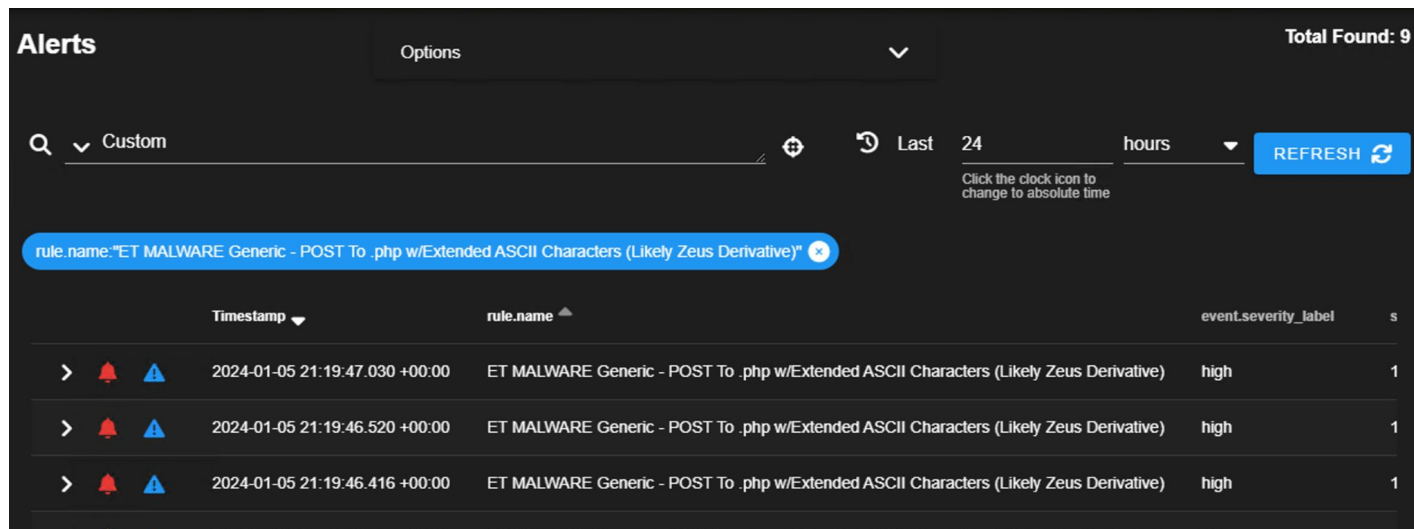
2. rule.name

3. event.module

4. event.severity_label

Count	rule.name	event.module	event.severity_label
45	GPL NETBIOS SMB-DS IPC\$ unicode share access	suricata	low
20	GPL NETBIOS SMB IPC\$ unicode share access	suricata	low
16	GPL SNMP public access udp	suricata	medium
9	ET MALWARE Generic - POST To .php w/Extended ASCII Characters (Likely Zeus Derivative)	suricata	high
9	ET MALWARE Zbot POST Request to C2	suricata	high
9	ET P2P BitTorrent peer sync	suricata	high
6	GPL P2P BitTorrent transfer	suricata	high

Security Onion Alert Panel Drilldown



The screenshot shows the Security Onion Alerts panel. At the top, there's a header with 'Alerts' and 'Options'. On the right, it says 'Total Found: 9'. Below the header, there's a search bar with a magnifying glass icon and a dropdown menu set to 'Custom'. To the right of the search bar are icons for adding filters, refreshing, and a time range selector set to 'Last 24 hours'. A 'REFRESH' button is also present. Below the search bar, a filter is applied: 'rule.name:"ET MALWARE Generic - POST To .php w/Extended ASCII Characters (Likely Zeus Derivative)"'. The main area displays a table of alerts.

	Timestamp ▼	rule.name ▲	event.severity_label	s
> 🔔 🔴	2024-01-05 21:19:47.030 +00:00	ET MALWARE Generic - POST To .php w/Extended ASCII Characters (Likely Zeus Derivative)	high	1
> 🔔 🔴	2024-01-05 21:19:46.520 +00:00	ET MALWARE Generic - POST To .php w/Extended ASCII Characters (Likely Zeus Derivative)	high	1
> 🔔 🔴	2024-01-05 21:19:46.416 +00:00	ET MALWARE Generic - POST To .php w/Extended ASCII Characters (Likely Zeus Derivative)	high	1

rule.name

In the top portion of this window is the Suricata engine that generated the alert data when traffic matched one of its rules.

- Alert data is an indicator of attack (IOA). An analyst may have to determine if it represents benign or malicious activity.
- Alert data from the Suricata NIDS stores entries in the Event Messages column that begin with text like “ET” (for “Emerging Threats,” an IDS rule source).

Packet Data

The lower portion of the panel displays a network packet analysis matching the filter criteria.

- Expanding the entries in the packet analyzer presents a detailed view of the data capture.

Expanding Security Onion Alert Data

This section of Security Onion's console provides information regarding the alert.

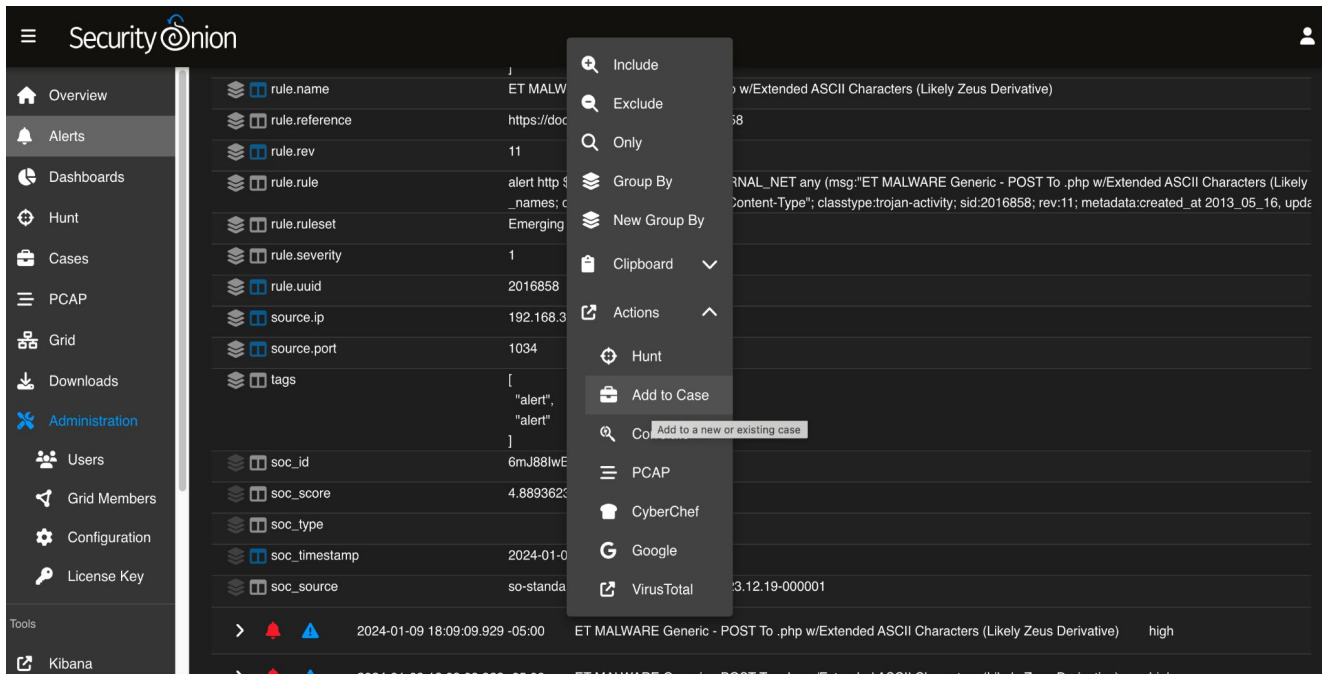
- This information is used to reveal identifying information about the attacker, including domain name registries and IP addresses.
- Other information may include country of origin and possibly the names, email addresses, and time of the event.

	Content-Length: 169 Connection: Keep-Alive Pragma: no-cache xWE.R[.6M.i2y..Yew.S2_9Q#.B.Q.....Q.B.=[_@tF.@9].v.....lo.s Q.q.8Vknh....1M.<9#+.....5xEa.....Xh.....&s.g....f.L...5m.U.....F% o]."
network.packet_source	wire/pcap
network.transport	TCP
observer.name	securityonion
rule.action	allowed
rule.category	A Network Trojan was detected
rule.gid	1
rule.metadata.created_at	["2013_05_16"]
rule.metadata.updated_at	["2020_08_17"]
rule.name	ET MALWARE Generic - POST To .php w/Extended ASCII Characters (Likely Zeus Derivative)
rule.reference	https://doc.emergingthreats.net/2016858
rule.rev	11
rule.rule	alert http \$HOME_NET any -> \$EXTERNAL_NET any (msg:"ET MALWARE Generic - POST To .php w/Extended ASCII Characters (Likely Zeus Derivative)" y, pcre:"^.{0,3}[x80-xff]{1,3}[x00-x7f]{1,3}[x80-xff]{1,3}[x80-xff]{1,3}/", http.header_names, content:"Referer", content:"Content-Type", cla
rule.ruleset	Emerging Threats
rule.severity	1

Incident Management and Case Creation

Inspecting an alert might lead to a decision to escalate for further investigation.

- Security Onion lets you create a new case or add to an existing one.
- Creating a case allows analysts to manage incidents and involve senior analysts when needed.





Activity

Security Onion and NSM

In this activity, you will continue your role as an SOC analyst for the California DMV.

- It's critical for your organization to understand the limits of what it can detect, adversarial tactics, and how to quickly apply lessons learned to mitigate newly discovered security vulnerabilities.
- For this activity, you will strengthen your knowledge of concepts related to Security Onion and network security monitoring (NSM).

Suggested Time
20 minutes



Time's Up!
Let's review

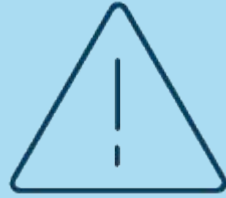


Questions?





Break
15 mins



HTTP File Extraction

Security Onion Demonstration Setup

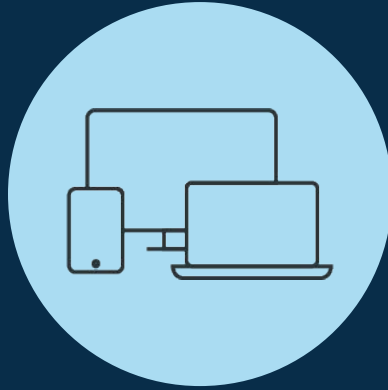
Sometimes an alert requires an analyst to do data mining.

- A security analyst must have a thorough understanding of how NSM tools are integrated.
- These skills help speed up incident and response efforts.





In the next guided tour, we'll use Security Onion as the starting point for learning other NSM tools for security investigations.



Instructor Demonstration

Security Onion



Activity

FTP File Extraction

In this activity, you will continue your role as an SOC analyst for the California DMV.

- Immediately after deploying your new defenses, your organization experienced an attack.
- You need to examine an alert to determine if any systems were breached and if any data was supplanted or exfiltrated from the network.

Suggested Time
20 minutes



Time's Up!
Let's review



Questions?





Next Class

Enterprise security management (ESM)



Thank You